

Adaptive Web Vulnerability Scan Report

Target: http://127.0.0.1:3000/#/

Scan ID: c0a5831d-8549-4b51-b1bf-6041f38e0e8a

Pages 25	Forms 17	Endpoints 110	Findings 17	API endpoints 175
GraphQL endpoints 2	Average anomaly 0	Passive score 64	High-risk endpoints 14	Schema fuzz probes 0
Open ports 1	Authenticated context No			

Scan Profile

Profile Bounty Standard	Detectors sqli, xss, csrf, auth_bypass	API fuzzing Enabled	GraphQL checks Enabled	Rate limit / sec 3.0
----------------------------	---	------------------------	---------------------------	-------------------------

Severity split: High 0, Medium 17, Low 0

Recon Intelligence

WAF Not detected	TLS Target is not HTTPS.	Screenshot failed	Missing headers 3
---------------------	-----------------------------	----------------------	----------------------

Technologies: none

Open ports: 8000 dev-http

Endpoint Risk Ranking

Risk	Method	Source	URL	Reasons
70	GET	directory-fuzzing	http://127.0.0.1:3000/openapi.json	openapi keyword, api keyword, directory-fuzzing source
65	get	script-analysis	http://127.0.0.1:3000/rest/user/authentication-details/	auth keyword, rest keyword, user keyword
65	get	script-analysis	http://127.0.0.1:3000/rest/user/login	login keyword, rest keyword, user keyword
60	get	script-analysis	http://127.0.0.1:3000/rest/admin	admin keyword, rest keyword
60	get	script-hidden-api	http://127.0.0.1:3000/Backup has been restored from	backup keyword, rest keyword
60	post	common-probe	http://127.0.0.1:3000/api/graphql	graphql keyword, api keyword
55	get	script-analysis	http://127.0.0.1:3000/rest/user/change-password?current=	rest keyword, user keyword, parameterized
55	get	script-analysis	http://127.0.0.1:3000/rest/user/security-question?email=	rest keyword, user keyword, parameterized

Risk	Method	Source	URL	Reasons
55	get	common-probe	http://127.0.0.1:3000/rest/products/search?q=apple	rest keyword, search keyword, parameterized
55	GET	directory-fuzzing	http://127.0.0.1:3000/admin	admin keyword, directory-fuzzing source
55	GET	directory-fuzzing	http://127.0.0.1:3000/debug	debug keyword, directory-fuzzing source
55	GET	directory-fuzzing	http://127.0.0.1:3000/swagger	swagger keyword, directory-fuzzing source
55	GET	directory-fuzzing	http://127.0.0.1:3000/swagger.json	swagger keyword, directory-fuzzing source
50	get	script-analysis	http://127.0.0.1:3000/rest/saveLoginIp	login keyword, rest keyword
45	post	common-probe	http://127.0.0.1:3000/graphql	graphql keyword
45	GET	directory-fuzzing	http://127.0.0.1:3000/upload	upload keyword, directory-fuzzing source
40	get	script-analysis	http://127.0.0.1:3000/api/Users	api keyword, user keyword
40	get	script-analysis	http://127.0.0.1:3000/rest/order-history	rest keyword, order keyword
40	get	script-analysis	http://127.0.0.1:3000/rest/track-order	rest keyword, order keyword
40	get	script-analysis	http://127.0.0.1:3000/rest/user	rest keyword, user keyword
40	get	script-analysis	http://127.0.0.1:3000/rest/user/reset-password	rest keyword, user keyword
40	get	script-analysis	http://127.0.0.1:3000/rest/user/whoami	rest keyword, user keyword
35	get	script-analysis	http://127.0.0.1:3000/accounting	account keyword
35	get	script-analysis	http://127.0.0.1:3000/file-upload	upload keyword
35	get	script-analysis	http://127.0.0.1:3000/login	login keyword

Scan Timeline

Progress	Phase	Message	Timestamp
5%	startup	Target reachable and scan initialized	2026-05-16T07:40:59.815806+00:00
30%	crawl	Mapped 25 pages, 17 forms, and 110 endpoints	2026-05-16T07:41:23.881238+00:00
88%	validation	Validated 17 candidate findings	2026-05-16T07:42:27.009930+00:00
92%	recon	Passive recon, endpoint risk, TLS, and low-impact discovery completed	2026-05-16T07:42:31.990836+00:00

Detector Registry

**sqli
injection**

query / form / api

Tests query parameters, forms, and API-like inputs for error-based, boolean-based, and time-delay SQL injection signals.

**xss
client-side**

query / form / api / dom

Checks reflected, DOM-rendered, and persistence-oriented XSS indicators across common input surfaces.

**csrf
workflow**

form

Flags state-changing forms and endpoints that appear to lack anti-CSRF protections.

**auth_bypass
authorization**

page / api

Looks for privileged or admin-style resources that are reachable without expected access controls.

API Surface

API endpoints
175

GraphQL endpoints
2

Parameterized endpoints
3

Methods
GET, POST

Discovery sources: bundle-candidate, common-probe, crawler, hidden-api, id-enumeration, script-analysis, script-hidden-api

Schema-Aware Fuzzing

Method	URL	Fields	Status	Reflected Fields	
No REST schema fuzz probes recorded.					

GraphQL URL	Fields	Status	Data Keys	Errors	
No GraphQL schema probes recorded.					

Detector Timings

Detector	Elapsed (ms)	Findings
sqli	50769.03	0
xss	8925.81	0
csrf	0.1	17
auth_bypass	3432.38	0

Findings

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/rest/user/login
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/rest/user/login with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status - -> -, length - -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/graphql

- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/graphql with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/api/graphql
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/api/graphql with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/api/Addressss
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/api/Addressss with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/api/Cards
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/api/Cards with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -

- **Remediation:** Add per-request CSRF tokens and validate them server-side.

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/api/Challenges
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/api/Challenges with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/api/Deliverys
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/api/Deliverys with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/api/Feedbacks
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/api/Feedbacks with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/api/Hints
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)

- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/api/Hints with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/api/Products
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/api/Products with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/api/Quantities
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/api/Quantities with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/api/Recycles
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/api/Recycles with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/api/SecurityQuestions
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/api/SecurityQuestions with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/rest/captcha
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/rest/captcha with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/rest/continue-code
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/rest/continue-code with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/rest/deluxe-membership
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -

- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/rest/deluxe-membership with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status - -> -, length - -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/rest/memories
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/rest/memories with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status - -> -, length - -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

Raw Findings Table

Detector	Severity	CVSS	Priority	Confidence	Signals	Method	Parameter	URL	Evic
csrf	medium	6.1	P2	medium (-)	-	post	-	http://127.0.0.1:3000/rest/user/login	POS form does expose an obvi CSRF toke field
csrf	medium	6.1	P2	medium (-)	-	post	-	http://127.0.0.1:3000/graphql	POS form does expose an obvi CSRF toke field
csrf	medium	6.1	P2	medium (-)	-	post	-	http://127.0.0.1:3000/api/graphql	POS form does expose an obvi CSRF toke field
csrf	medium	6.1	P2	medium (-)	-	post	-	http://127.0.0.1:3000/api/Addressss	POS form does expose an obvi CSRF toke field

Detector	Severity	CVSS	Priority	Confidence	Signals	Method	Parameter	URL	Evidence
csrf	medium	6.1	P2	medium (-)	-	post	-	http://127.0.0.1:3000/api/Cards	POST form does not expect an obvious CSRF token field
csrf	medium	6.1	P2	medium (-)	-	post	-	http://127.0.0.1:3000/api/Challenges	POST form does not expect an obvious CSRF token field
csrf	medium	6.1	P2	medium (-)	-	post	-	http://127.0.0.1:3000/api/Deliverys	POST form does not expect an obvious CSRF token field
csrf	medium	6.1	P2	medium (-)	-	post	-	http://127.0.0.1:3000/api/Feedbacks	POST form does not expect an obvious CSRF token field
csrf	medium	6.1	P2	medium (-)	-	post	-	http://127.0.0.1:3000/api/Hints	POST form does not expect an obvious CSRF token field
csrf	medium	6.1	P2	medium (-)	-	post	-	http://127.0.0.1:3000/api/Products	POST form does not expect an obvious CSRF token field
csrf	medium	6.1	P2	medium (-)	-	post	-	http://127.0.0.1:3000/api/Quantities	POST form does not expect an obvious CSRF token field
csrf	medium	6.1	P2	medium (-)	-	post	-	http://127.0.0.1:3000/api/Recycles	POST form does not expect an obvious CSRF token field

Detector	Severity	CVSS	Priority	Confidence	Signals	Method	Parameter	URL	Evidence
csrf	medium	6.1	P2	medium (-)	-	post	-	http://127.0.0.1:3000/api/SecurityQuestions	POST form does not expect an obvious CSRF token field
csrf	medium	6.1	P2	medium (-)	-	post	-	http://127.0.0.1:3000/rest/captcha	POST form does not expect an obvious CSRF token field
csrf	medium	6.1	P2	medium (-)	-	post	-	http://127.0.0.1:3000/rest/continue-code	POST form does not expect an obvious CSRF token field
csrf	medium	6.1	P2	medium (-)	-	post	-	http://127.0.0.1:3000/rest/deluxe-membership	POST form does not expect an obvious CSRF token field
csrf	medium	6.1	P2	medium (-)	-	post	-	http://127.0.0.1:3000/rest/memories	POST form does not expect an obvious CSRF token field